BTEUP EXAM NOTES | ENGLISH EDITION

Information Security

Unit 4: Network Security Products: Firewall, IDS/IPS, VPN, Gateways

About these notes

Part A explains every topic in very simple English with real-life examples, so a beginner can understand it from zero.

Part B gives important exam questions with full 5-mark model answers, ready to write in the exam.

At the end: quick revision sheet, common mistakes, and a self-test.

Syllabus covered (Unit 4)

Network Security Products: Firewall, IDS/IPS, VPN Concentrator, Content Screening Gateways, etc.

Unit Overview and Contents

Simple idea: Think of a bank. It has a **security guard at the gate** (firewall), an **alarm and CCTV** (IDS), an **automatic door lock that closes on a thief** (IPS), a **secure private road for staff and branches** (VPN concentrator) and a **bag checker** who stops dangerous items (content screening gateway). This unit explains these network security products, what each does and how they differ.

Topic	Exam importance	Where in notes
Firewall (types, rules, DMZ)	Very High	Part A: Topic 2 | Part B: Q1, Q2, Q3, Q4
IDS and IPS	Very High	Part A: Topic 3 | Part B: Q5, Q6, Q7, Q11
VPN Concentrator	High	Part A: Topic 4 | Part B: Q8
Content Screening Gateways, Proxy	High	Part A: Topic 5 | Part B: Q9, Q10
Other products (UTM, WAF, NAC, SIEM)	Medium	Part A: Topic 1, 5 | Part B: Q12

Contents

Part A: Easy Explanation	Part B: Important Questions with Answers
Topic 1: Network security products overview Topic 2: Firewall Topic 3: IDS and IPS Topic 4: VPN Concentrator Topic 5: Content Screening Gateways and others	Q1 Firewall, working and rules (Very Likely) Q2 Types of firewall (Very Likely) Q3 DMZ (Likely) Q4 Advantages and limitations of firewall (Likely) Q5 IDS, types and detection methods (Very Likely) Q6 IPS and IDS vs IPS (Very Likely) Q7 Firewall vs IDS (Likely) Q8 VPN Concentrator (Very Likely) Q9 Content Screening Gateway (Very Likely) Q10 Proxy server (Possible) Q11 NIDS vs HIDS (Possible) Q12 UTM, WAF, NAC, SIEM (Possible)

How to study this unit (suggested time: 1 day)

1) Read Part A once to understand. 2) Read Part B answers and copy each answer on paper with the diagram. 3) Revise using the Quick Revision Sheet. 4) Attempt the Self-Test without looking.

PART A: Easy Explanation (Simple English)

Topic 1: Network Security Products (overview)

One product cannot stop every attack. So organizations use **many products together**. This idea is called **Defence in Depth** (layered security).

Product	Main job	Type of protection
Firewall	Allows or blocks traffic using rules	Preventive
IDS	Watches traffic and raises an alert	Detective
IPS	Detects and automatically blocks attacks	Preventive + detective
VPN Concentrator	Creates and manages many secure tunnels	Secure access
Content Screening Gateway	Filters web, email and downloads	Content control

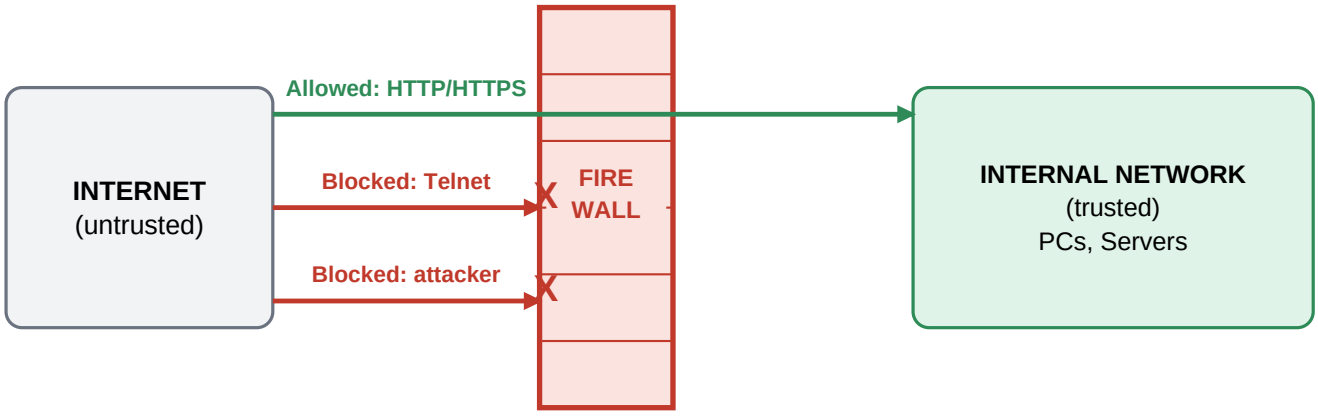
Topic 2: Firewall

Real-life example

A firewall is the **security guard at your society gate**. He checks every visitor against a list: residents can enter, known delivery boys can enter, strangers and troublemakers are stopped.

Definition

A **firewall** is a hardware or software security system that monitors and controls incoming and outgoing network traffic using a set of security **rules**. It acts as a barrier between a trusted internal network and an untrusted external network (the Internet).



Firewall checks every packet against security rules (allow / deny)

Figure 1: Firewall between Internet and internal network

How a firewall works: rules (ACL)

Each packet is compared with a list of rules **from top to bottom**. The first matching rule decides allow or deny. At the end there is a **default deny** rule: anything not allowed is blocked.

No.	Source	Destination	Protocol / Port	Action
1	Any	Web server 192.168.1.10	TCP 80, 443	**ALLOW**
2	Any	Mail server 192.168.1.20	TCP 25	**ALLOW**

No.	Source	Destination	Protocol / Port	Action
3	10.10.5.0/24	Any	Any	**DENY**
4	Any	Any	Any	**DENY** (default)

Types of firewall

- **1. Packet filtering firewall (Layer 3-4):** checks only the packet header (source/destination IP, port, protocol). Very fast but **stateless**; it cannot see the data and can be fooled by IP spoofing.
- **2. Stateful inspection firewall:** remembers the state of every connection in a **state table**. It allows a reply only if it belongs to a connection started from inside. More secure than packet filtering.
- **3. Circuit-level gateway (Layer 5):** checks the TCP handshake to see that a session is legitimate. Does not inspect the data.
- **4. Application / Proxy firewall (Layer 7):** sits in the middle as a proxy and inspects the actual content (HTTP, FTP). Hides internal IPs. Most secure but slower.
- **5. Next-Generation Firewall (NGFW):** stateful inspection + deep packet inspection + IPS + application and user awareness + malware sandbox.

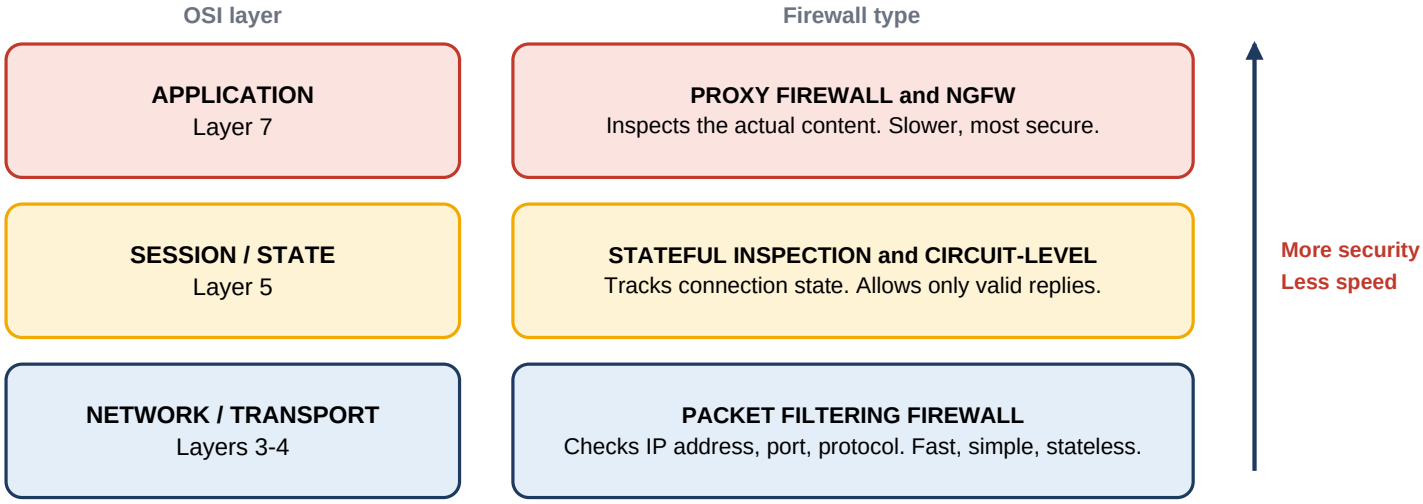


Figure 2: Firewall types by layer

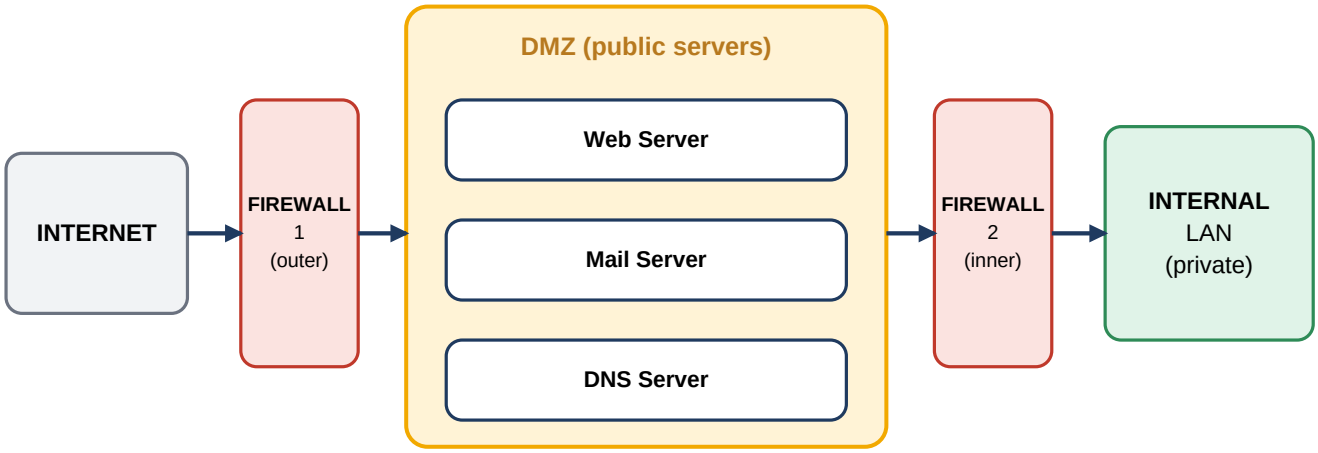
- **Hardware firewall:** dedicated device at the network edge (Cisco ASA, Fortinet). **Software firewall:** installed on a PC or server (Windows Defender Firewall, iptables).
- **Network firewall** protects the whole network; **host-based firewall** protects one machine.

DMZ (Demilitarized Zone)

Real-life example

A reception area of an office: visitors can enter the reception (public servers) but cannot go inside the office (internal LAN) without another check.

- A **DMZ** is a separate network zone between the Internet and the internal LAN that hosts **public-facing servers** (web, mail, DNS).
- It is placed between two firewalls (outer and inner) or on a third interface of one firewall.
- If a DMZ server is hacked, the attacker still cannot reach the internal LAN directly.



If a DMZ server is hacked, the inner firewall still protects the internal LAN

Figure 3: DMZ architecture with two firewalls

Advantages of firewall	Limitations of firewall
Controls access using rules Blocks unauthorized traffic Hides internal network (NAT) Logs traffic for audit Enforces security policy	Cannot stop insider attacks Cannot stop traffic that bypasses it (modem, USB) Cannot detect viruses in allowed traffic (basic types) Wrong rules create holes Cannot see inside encrypted traffic Can become a bottleneck / single point of failure

Topic 3: IDS and IPS

3(a) IDS (Intrusion Detection System)

Real-life example

An IDS is the **burglar alarm and CCTV**. It notices a suspicious person and rings the alarm, but it does not catch the thief by itself.

Definition

An **IDS** is a device or software that **monitors** network traffic or system activity for malicious behaviour or policy violations and **generates alerts**. It is **passive**: it does not block traffic.

- **NIDS (Network-based IDS):** placed at a point in the network; watches all traffic using a mirror (SPAN) port or TAP. Example: Snort, Suricata.
- **HIDS (Host-based IDS):** installed on one host; watches logs, system files, processes and registry. Example: OSSEC.
- **Signature-based detection:** matches traffic with a database of known attack patterns. Accurate for known attacks, misses new ones.
- **Anomaly-based detection:** learns normal behaviour (baseline) and alerts on deviation. Can find unknown attacks but gives more false alarms.
- **False positive:** alarm for normal traffic. **False negative:** real attack missed.

3(b) IPS (Intrusion Prevention System)

Real-life example

An IPS is an **automatic door that locks the moment it sees a thief**. It does not just ring the alarm; it stops the thief.

Definition

An **IPS** is a security device placed **inline** (directly in the traffic path) that detects malicious traffic and **automatically blocks it**.

- **Actions:** drop the packet, block the source IP, reset the connection, alert the admin.
- **Risks:** a false positive can block genuine users; being inline, it can add delay and be a single point of failure.
- Examples: Snort (inline mode), Suricata, Cisco Firepower.

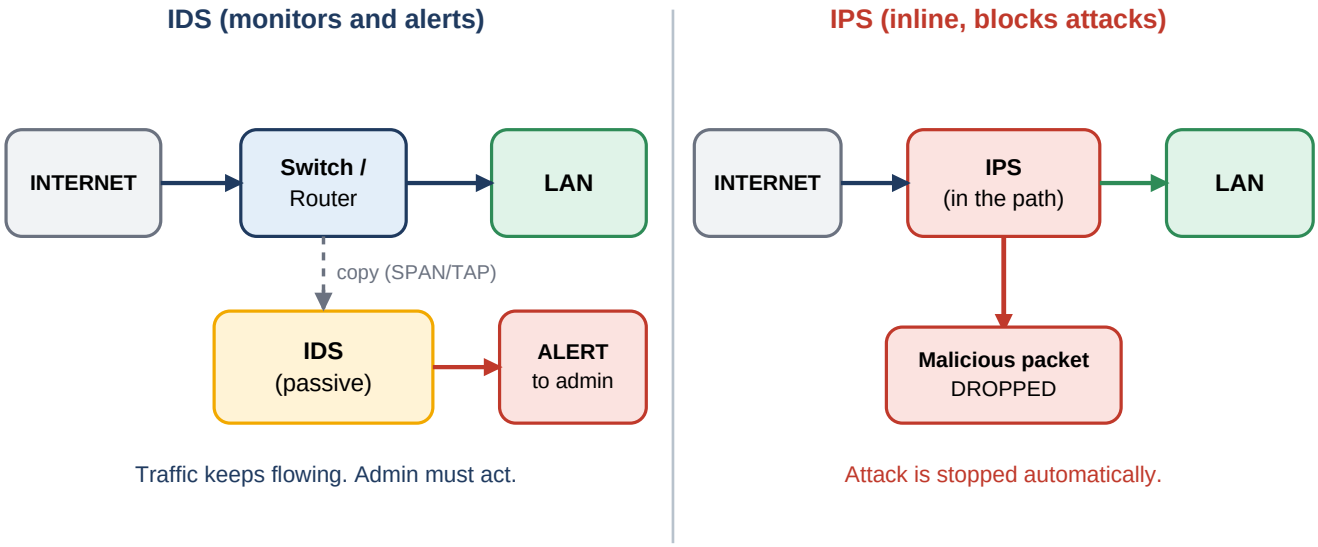


Figure 4: IDS vs IPS placement

Point	IDS	IPS
Full form	Intrusion Detection System	Intrusion Prevention System
Placement	Out of band (gets a copy of traffic)	Inline (in the traffic path)
Action	Detects and alerts only	Detects and blocks
Effect on traffic	None	Can delay or block traffic
Response	Manual (admin acts)	Automatic
Type	Detective	Preventive

Topic 4: VPN Concentrator

Real-life example

Imagine a company with one **secure private gate for employees working from home and from branches**. All of them arrive through the Internet, but the gate checks identity and every road to it is a locked tunnel. That gate is the VPN concentrator.

Definition

A **VPN concentrator** is a dedicated network device that **creates, manages and terminates a large number of VPN tunnels** for remote users and branch offices. It authenticates users and encrypts/decrypts their data.

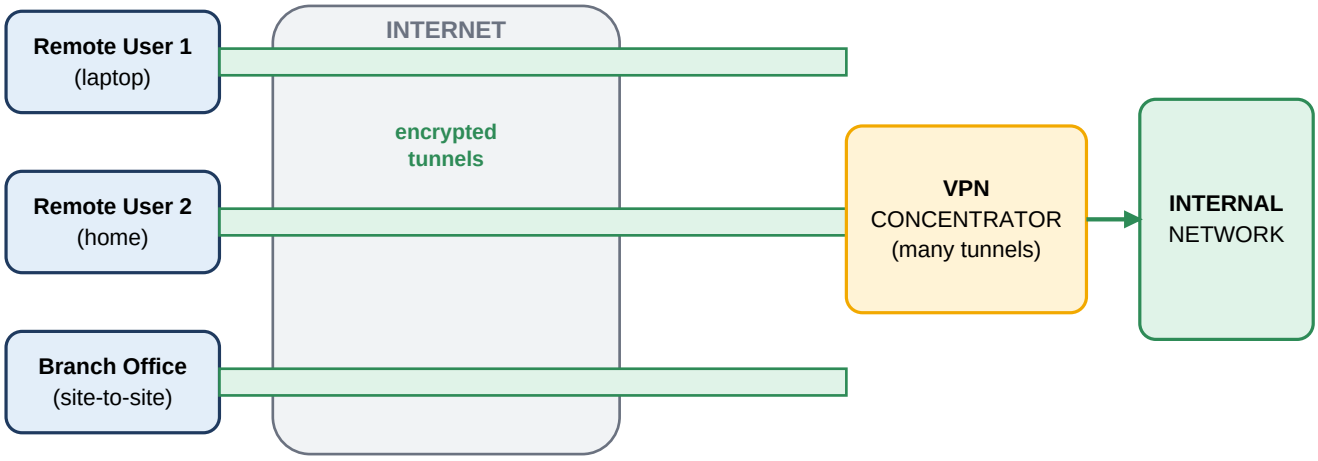


Figure 5: VPN concentrator with remote-access and site-to-site tunnels

Main functions

- **Authentication:** checks users with passwords, tokens, certificates or a RADIUS/LDAP server.
- **Encryption and tunnelling:** uses **IPSec**, SSL/TLS or L2TP to build encrypted tunnels.
- **Address assignment:** gives remote users an internal IP address.
- **Scalability:** handles hundreds or thousands of users at once using hardware acceleration.
- **Policy and logging:** controls who can reach which resource and records sessions.
- **Types of VPN served:** Remote-access VPN (employee to office) and Site-to-site VPN (office to office).
- **Placement:** usually in parallel with or behind the firewall, often in the DMZ.
- **Difference from a firewall:** a firewall filters traffic; a VPN concentrator builds secure tunnels. Today many firewalls include VPN concentrator features.

Topic 5: Content Screening Gateways and Other Products

5(a) Content Screening Gateway

Real-life example

At an airport, every bag goes through a scanner. Dangerous items are removed before the bag enters. A content screening gateway scans **web pages, emails and downloads** in the same way.

Definition

A **content screening gateway** (content filter) is a security device or software placed between users and the Internet that **inspects the content** of web traffic and email and blocks harmful or unwanted material according to policy.

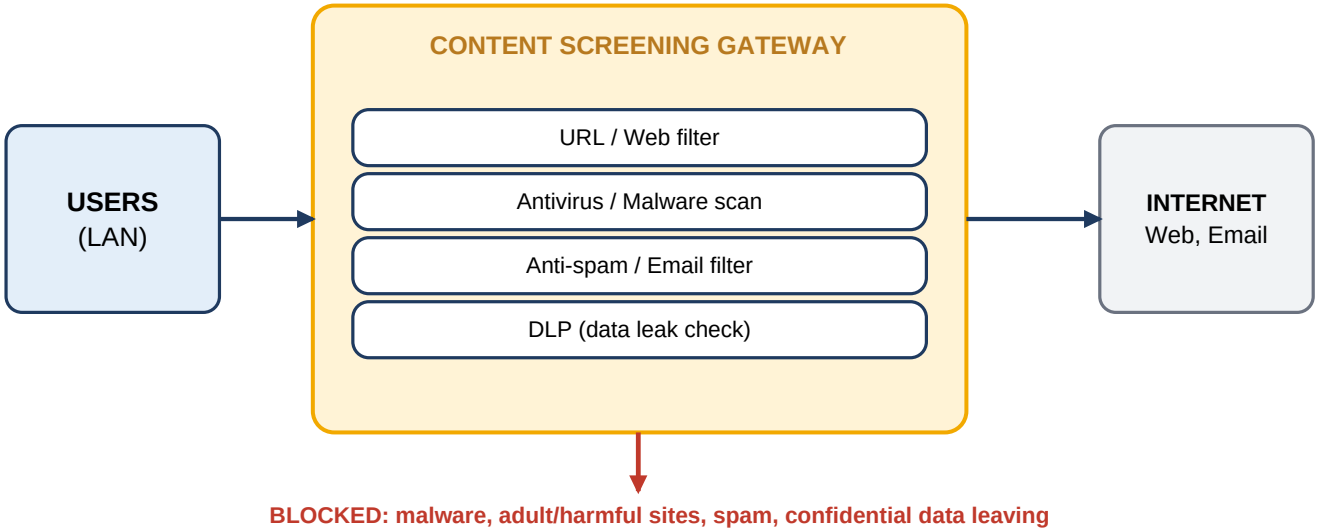


Figure 6: Content screening gateway

- **URL / web filtering:** blocks categories such as adult, gambling, social media or known malicious sites.
- **Antivirus / anti-malware scanning:** scans downloads and attachments for malware.
- **Anti-spam and phishing filter:** email gateway removes spam and phishing mails.
- **DLP (Data Loss Prevention):** stops confidential data from leaving the organization.
- **Other features:** file-type blocking, application control, SSL inspection, bandwidth control, reports.
- **Types:** web gateway (proxy based) and email gateway. **Examples:** Squid with filters, Cisco WSA/ESA, Forcepoint, Barracuda.
- **Benefits:** blocks malware, enforces acceptable-use policy, saves bandwidth, improves productivity, prevents data leaks.

5(b) Proxy Server

- A **proxy server** is an intermediary: the client sends its request to the proxy, and the proxy fetches the page on its behalf.
- Uses: hides internal IPs, **filters** content, **caches** pages for speed, logs user activity. A **reverse proxy** protects servers by sitting in front of them.



Website sees only the proxy's IP. Proxy can filter, cache and log.

Figure 7: Proxy server

5(c) Other network security products (etc.)

Product	What it does
UTM (Unified Threat Management)	All-in-one box: firewall + IPS + antivirus + VPN + content filter + anti-spam
WAF (Web Application Firewall)	Protects web applications from SQL injection, XSS at Layer 7
NAC (Network Access Control)	Lets only authenticated, compliant devices join the network
SIEM	Collects and correlates logs from many devices to find attacks
Honeypot	A decoy system that attracts attackers so their methods can be studied

PART B: Important Questions with Model Answers (English)

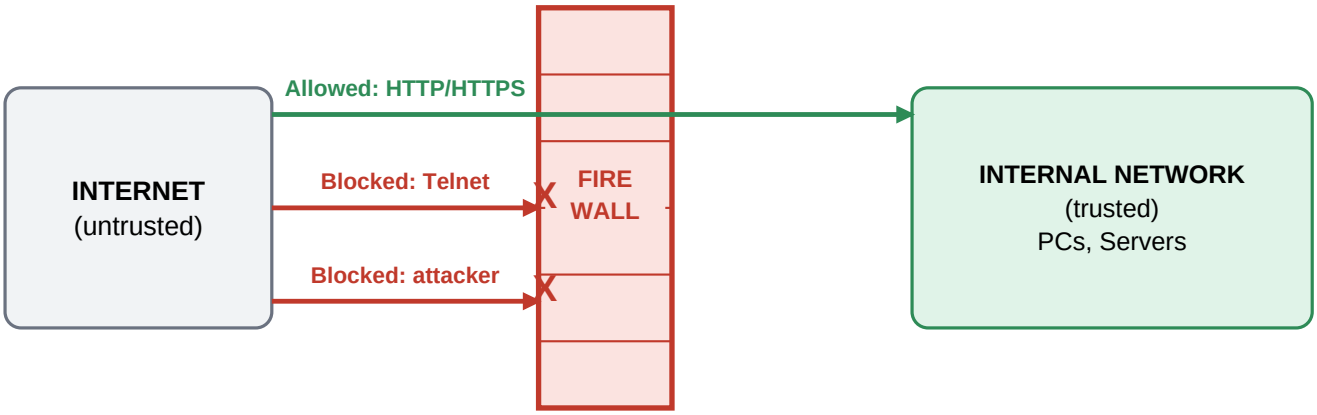
Priority: **Very Likely** = appears most often in BTEUP. **Likely** = good chance. **Possible** = can appear. Each answer follows the exam format: **Definition, Points, Diagram/Table, Conclusion**.

Q1. What is a Firewall? Explain how it works. — VERY LIKELY

Definition / Introduction: A firewall is a hardware or software security system that monitors and controls incoming and outgoing network traffic based on a set of security rules. It forms a barrier between a trusted internal network and an untrusted external network such as the Internet.

Points

- **Working:** each packet is compared with the rule list (ACL) from top to bottom; the first matching rule decides ALLOW or DENY.
- Rules use source IP, destination IP, protocol and port number.
- A final **default deny** rule blocks everything not explicitly allowed.
- Firewalls can also perform NAT (hide internal IPs), logging and VPN.
- **Types:** packet filtering, stateful inspection, circuit-level gateway, application/proxy firewall, NGFW. **Forms:** hardware, software, host-based, network-based.



Firewall checks every packet against security rules (allow / deny)

Figure: Firewall

No.	Source	Destination	Port	Action
1	Any	Web server	80, 443	ALLOW
2	10.10.5.0/24	Any	Any	DENY
3	Any	Any	Any	DENY (default)

Conclusion: A firewall is the first line of defence of a network and enforces the organization's access policy.

Q2. Explain the types of firewall. VERY LIKELY

Definition / Introduction: Firewalls are classified by the layer at which they inspect traffic and by how much information they use to decide.

Points

- **Packet filtering (Layer 3-4):** checks IP, port and protocol in the header only. Fast, cheap, stateless. Weak against spoofing; cannot see data.
- **Stateful inspection:** keeps a state table of active connections and allows only valid return traffic. More secure.
- **Circuit-level gateway (Layer 5):** validates the TCP handshake of a session; no content inspection.
- **Application / proxy firewall (Layer 7):** acts as a proxy and inspects the content of applications such as HTTP and FTP. Hides internal IPs. Slower.
- **NGFW:** combines stateful inspection with deep packet inspection, IPS, application and user control and malware protection.

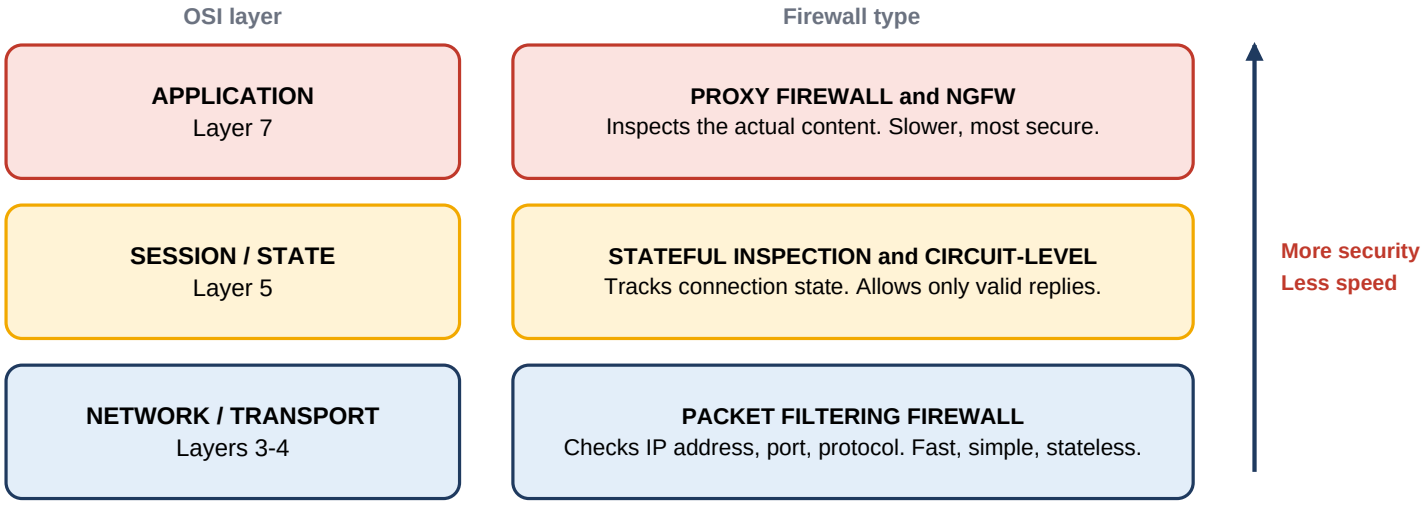


Figure: Firewall types by layer

Type	Layer	Speed	Security
Packet filtering	3-4	Very fast	Low
Stateful	3-5	Fast	Medium
Proxy / Application	7	Slow	High
NGFW	3-7	Medium	Very high

Conclusion: The choice of firewall depends on the required level of security and performance.

Q3. What is a DMZ? Explain with a diagram. LIKELY

Definition / Introduction: A DMZ (Demilitarized Zone) is a separate network segment between the Internet and the internal network that hosts public-facing servers such as web, mail and DNS servers.

Points

- The DMZ is placed between two firewalls: the **outer firewall** allows Internet users to reach only DMZ servers; the **inner firewall** protects the internal LAN.
- A DMZ can also be built on a third interface of a single firewall.
- **Benefit:** if a public server is hacked, the attacker is still stopped by the inner firewall.
- Internal users and servers are never directly exposed to the Internet.

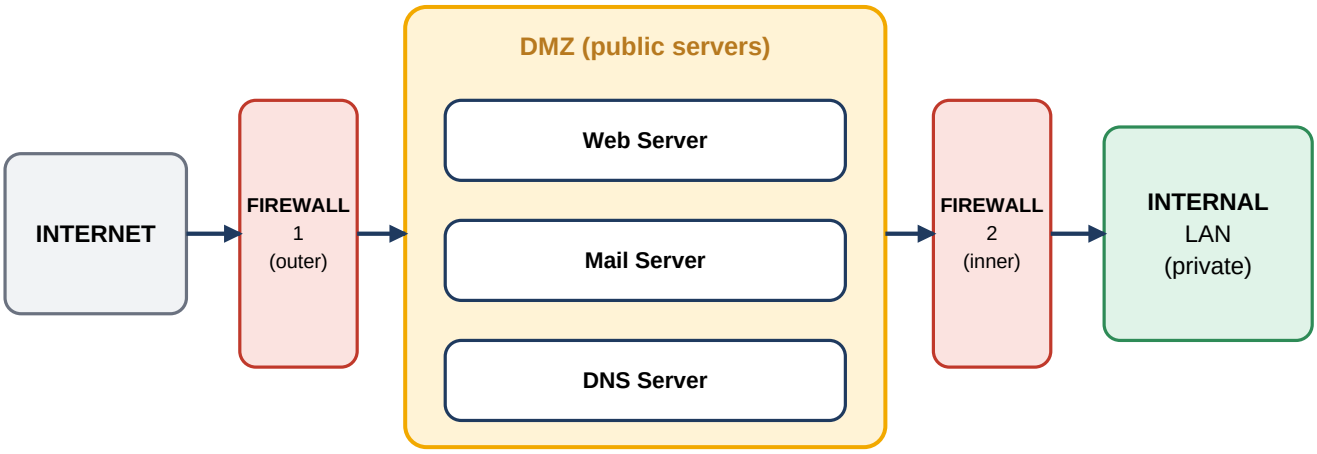


Figure: DMZ with two firewalls

Conclusion: A DMZ allows services to be public while keeping the private network safe.

Q4. Write the advantages and limitations of a firewall. LIKELY

Definition / Introduction: A firewall is an essential security device, but it is not a complete solution.

Points

- **Advantages:** controls access with rules; blocks unauthorized and malicious traffic; hides internal network using NAT; logs traffic for auditing; enforces security policy; supports VPN and DMZ.
- **Limitations:** cannot protect against insider attacks; cannot control traffic that does not pass through it (modems, USB, WiFi).
- Basic firewalls cannot detect viruses inside allowed traffic or inspect encrypted traffic.
- Wrong configuration creates security holes; it can become a performance bottleneck or single point of failure.

Advantages	Limitations
Access control	No protection from insiders
NAT hides internal IPs	Cannot stop bypass traffic
Logging and audit	Cannot scan encrypted traffic
Policy enforcement	Misconfiguration risk

Conclusion: A firewall must be combined with IDS/IPS, antivirus and user awareness for complete security.

Q5. What is an IDS? Explain its types and detection methods. VERY LIKELY

Definition / Introduction: An Intrusion Detection System (IDS) is a device or software that monitors network traffic or system activity for malicious behaviour or policy violations and generates alerts. It is passive and does not block traffic.

Points

- **NIDS (Network-based):** monitors network traffic through a SPAN port or TAP. Example: Snort, Suricata.
- **HIDS (Host-based):** installed on a host; monitors logs, files and processes. Example: OSSEC.
- **Signature-based detection:** compares activity with known attack patterns.
- **Anomaly-based detection:** compares activity with a learned normal baseline.
- **Alerts:** a false positive is a false alarm; a false negative is a missed attack.

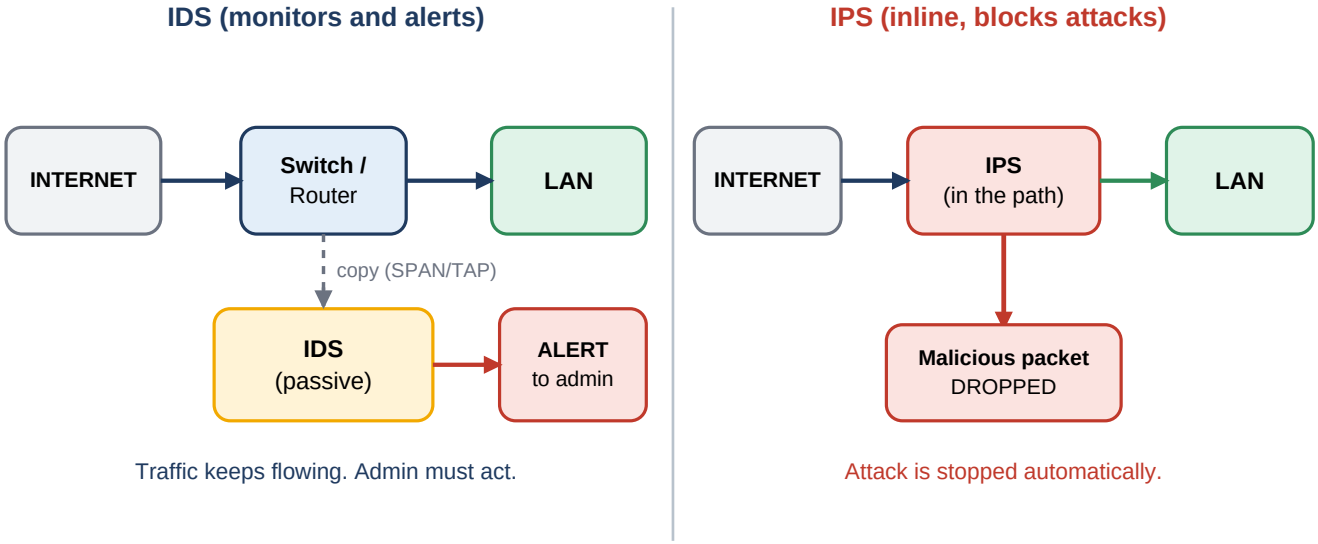


Figure: IDS and IPS

Point	Signature-based	Anomaly-based
Detects	Known attacks	Known and unknown attacks
False alarms	Few	More
Needs	Regular signature updates	Training on normal traffic

Conclusion: IDS gives visibility into attacks, but a human must respond to its alerts.

Q6. What is an IPS? Differentiate between IDS and IPS. VERY LIKELY

Definition / Introduction: An Intrusion Prevention System (IPS) is a security device placed inline in the traffic path that detects malicious traffic and automatically blocks it.

Points

- **Actions of IPS:** drop malicious packets, block the source IP, reset the connection and alert the admin.
- **Risk:** false positives can block genuine traffic; it may add delay and be a single point of failure.
- IDS is detective and passive; IPS is preventive and active.

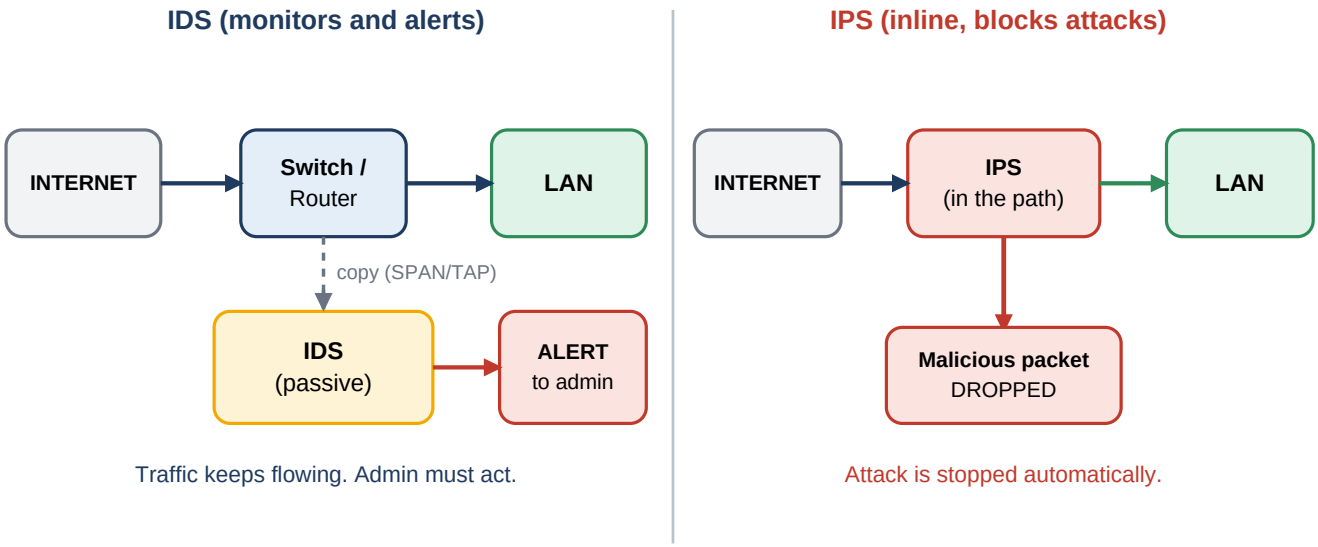


Figure: IDS vs IPS placement

Point	IDS	IPS
Placement	Out of band (copy of traffic)	Inline (in the path)
Action	Detect and alert	Detect and block
Effect on traffic	None	May delay / block
Response	Manual	Automatic
Failure impact	Network keeps working	May stop traffic

Conclusion: Modern products often combine both as IDPS or build IPS into the next-generation firewall.

Q7. Differentiate between Firewall and IDS. LIKELY

Definition / Introduction: A firewall controls which traffic may enter or leave a network using rules, while an IDS analyses traffic or activity to detect attacks and raise alerts.

Points

- Both are complementary and are used together for layered security.

Point	Firewall	IDS
Main job	Allow or block traffic	Detect attacks and alert
Decision based on	Rules (IP, port, protocol)	Patterns / behaviour analysis
Nature	Preventive	Detective
Placement	At network boundary, inline	Inside network, passive (SPAN/TAP)
Can stop an attack	Yes (by rules)	No, only alerts

Conclusion: A firewall blocks known-bad traffic and an IDS finds what passes through; together they are stronger.

Q8. What is a VPN Concentrator? Explain its functions. VERY LIKELY

Definition / Introduction: A VPN concentrator is a dedicated network device that creates, manages and terminates a large number of VPN tunnels for remote users and branch offices. It authenticates users and encrypts and decrypts their data.

Points

- **Authentication:** verifies users using passwords, tokens, certificates or RADIUS/LDAP.
- **Encryption and tunnelling:** IPSec, SSL/TLS or L2TP protect data across the Internet.
- **IP assignment, policy control and logging** for each remote user.
- **Scalability:** hardware acceleration allows hundreds or thousands of simultaneous tunnels.
- **Types served:** remote-access VPN and site-to-site VPN. Placed in parallel with or behind the firewall (often in the DMZ).

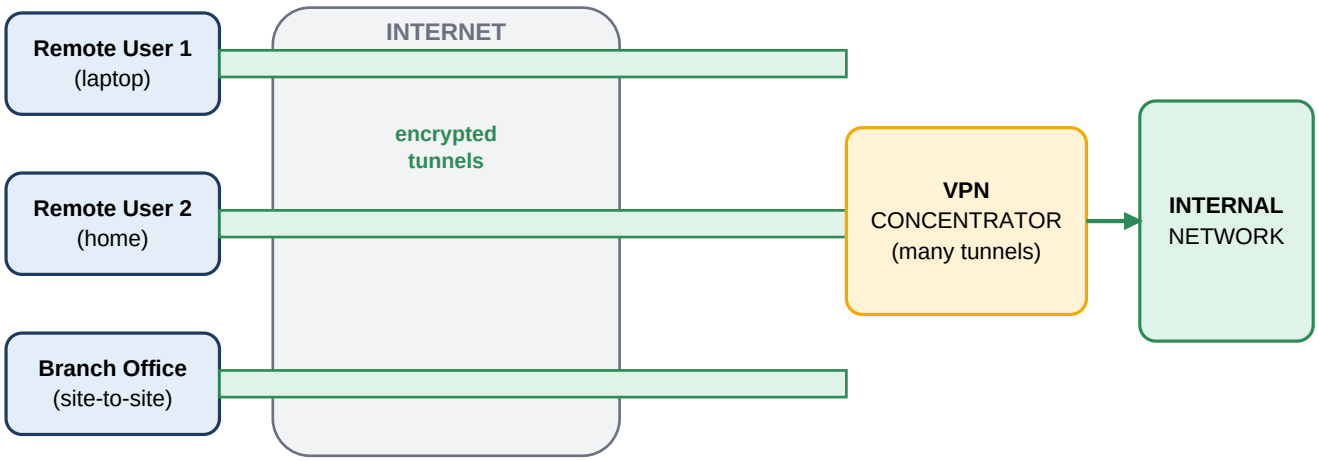


Figure: VPN concentrator

Conclusion: A VPN concentrator gives many users secure, centrally managed access to the private network.

Q9. What is a Content Screening Gateway? Explain its features. VERY LIKELY

Definition / Introduction: A content screening gateway is a security device or software placed between users and the Internet that inspects web and email content and blocks harmful or unwanted material according to the organization's policy.

Points

- **URL / web filtering:** blocks categories such as adult, gambling and malicious sites.
- **Antivirus / anti-malware scanning** of downloads and attachments.
- **Anti-spam and anti-phishing** filtering of email.
- **DLP:** prevents confidential data from leaving the network.
- **Other:** file-type blocking, application control, SSL inspection, bandwidth management, reporting.

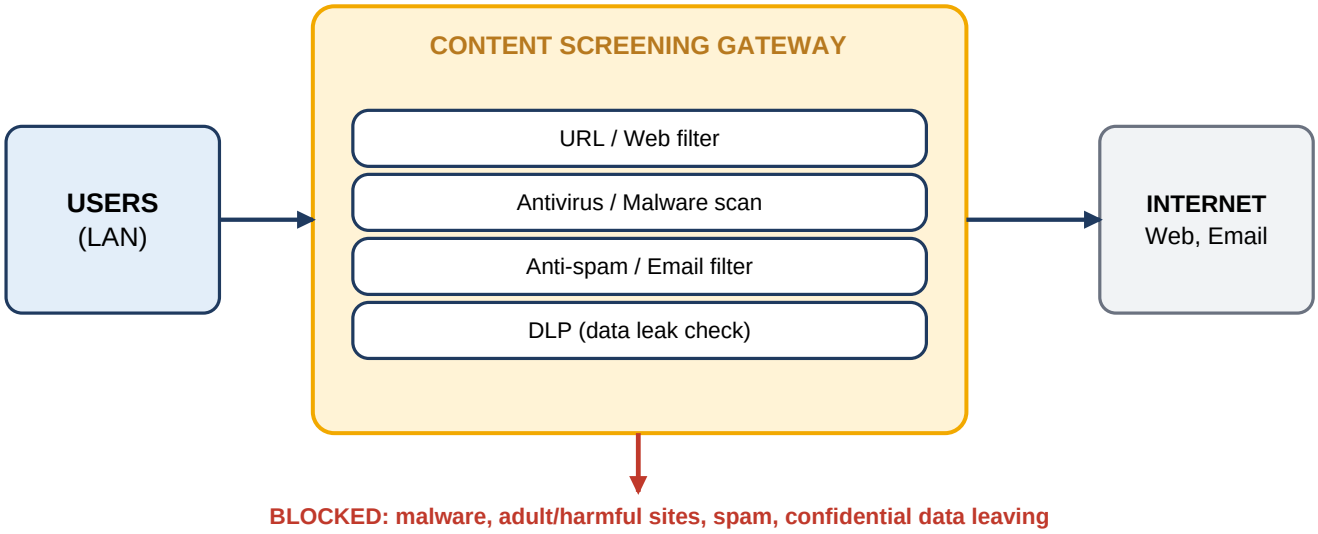


Figure: Content screening gateway

Conclusion: It protects users from web and email threats and enforces the organization's acceptable-use policy.

Q10. What is a Proxy Server? Explain its uses. POSSIBLE

Definition / Introduction: A proxy server is an intermediary server between a client and the Internet. The client sends requests to the proxy, which forwards them to the destination and returns the response.

Points

- **Hides identity:** the website sees only the proxy's IP address.
- **Filtering:** blocks unwanted sites and scans content.
- **Caching:** stores frequently used pages to save bandwidth and increase speed.
- **Logging and control:** records user activity; supports authentication.
- **Forward proxy** serves clients; **reverse proxy** sits in front of servers to protect and balance load.

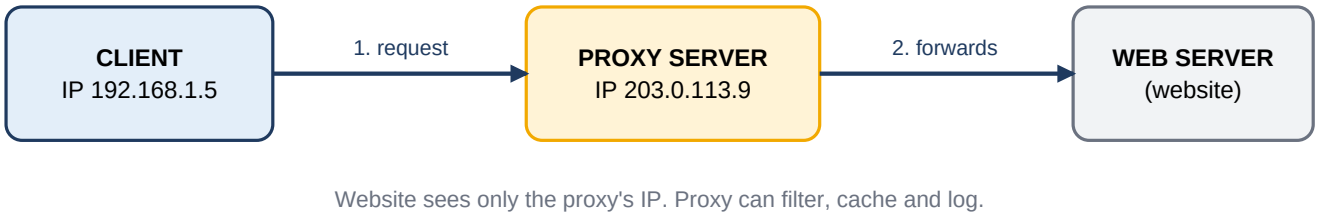


Figure: Proxy server

Conclusion: Proxy servers improve security, privacy and performance of web access.

Q11. Differentiate between NIDS and HIDS. POSSIBLE

Definition / Introduction: NIDS monitors traffic of a whole network segment, whereas HIDS monitors the activity of a single host.

Points

- Both are IDS types and give the best coverage when used together.

Point	NIDS	HIDS
Full form	Network-based IDS	Host-based IDS
Monitors	Network traffic (packets)	Logs, files, processes, registry
Placement	At a network point (SPAN/TAP)	Installed on each host
Coverage	Whole network segment	One machine
Encrypted traffic	Cannot read content	Can see data after decryption
Examples	Snort, Suricata	OSSEC, Tripwire

Conclusion: NIDS gives wide visibility and HIDS gives deep visibility into a host.

Q12. Write short notes on UTM, WAF, NAC and SIEM. POSSIBLE

Definition / Introduction: Besides firewalls and IDS/IPS, organizations use several other network security products.

Points

- **UTM (Unified Threat Management):** an all-in-one device combining firewall, IPS, antivirus, VPN, content filter and anti-spam. Easy to manage; good for small organizations.
- **WAF (Web Application Firewall):** protects web applications from SQL injection, XSS and other Layer-7 attacks.
- **NAC (Network Access Control):** allows only authenticated and policy-compliant devices to connect to the network.
- **SIEM (Security Information and Event Management):** collects and correlates logs from many devices, raises alerts and helps investigation.

Product	Protects	Works at
UTM	Whole network (many functions)	Network edge
WAF	Web applications	Layer 7
NAC	Network entry (devices)	Access layer
SIEM	Visibility across systems	Log analysis

Conclusion: These products add more layers to defence in depth.

Quick Revision Sheet (read the night before)

Term	Remember this
Firewall	Allow/deny traffic by rules (ACL), top to bottom, default deny
Firewall types	Packet filter, Stateful, Circuit-level, Proxy/Application, NGFW
Packet filter	L3-4, header only, stateless, fast
Stateful	State table, allows valid replies
Proxy firewall	L7, inspects content, hides IP, slow
DMZ	Zone between 2 firewalls for web/mail/DNS servers
IDS	Passive, out of band, detects and alerts (Snort)
IPS	Inline, active, detects and blocks
NIDS / HIDS	Network traffic / one host
Detection	Signature (known) and Anomaly (unknown, more false alarms)
False +ve / -ve	False alarm / missed attack
VPN concentrator	Many VPN tunnels, authenticates, encrypts (IPSec/SSL)
Content gateway	URL filter, antivirus, anti-spam, DLP
Proxy server	Intermediary, hides IP, filters, caches
UTM / WAF / NAC / SIEM	All-in-one / web app firewall / device access control / log correlation

Memory tricks

IDS = I Detect Silently (alert only). **IPS = I Prevent Strictly** (blocks).
Firewall layers: Packet = 3-4, Stateful = 5 (state), Proxy = 7 (application).
Content gateway: U-A-A-D = URL, Antivirus, Anti-spam, DLP.
DMZ = the **reception** of your network: public can come, private stays safe.

Common Mistakes Students Make

- Saying IDS blocks attacks. **IDS only detects and alerts**; IPS blocks.
- Writing that a packet filtering firewall checks the data. It checks only **header information**.
- Mixing up firewall (traffic control by rules) and VPN concentrator (tunnel manager).
- Forgetting the **default deny** rule and the top-to-bottom rule order.
- Not drawing diagrams (firewall, DMZ, IDS vs IPS).
- Not giving examples such as Snort, Cisco ASA, Squid.

Self-Test (answer without looking, 5 marks each)

- Explain the types of firewall with a table.
- What is a DMZ? Draw and explain.
- Differentiate between IDS and IPS.
- What is a VPN concentrator? Write its functions.
- Explain the features of a content screening gateway.

Self-Test Answers (check after writing)

1. Packet filtering (L3-4, header, stateless), Stateful inspection (state table), Circuit-level gateway (L5, TCP handshake), Application/Proxy (L7, content), NGFW (all plus IPS and application control). Draw the table from Q2.

2. A DMZ is a network zone between two firewalls that holds public servers (web, mail, DNS). If a DMZ server is hacked, the inner firewall still protects the internal LAN. Draw Figure 3.

3. IDS: out of band, passive, detects and alerts, manual response. IPS: inline, active, detects and blocks automatically, can delay traffic.

4. A dedicated device that creates and manages many VPN tunnels. Functions: authentication, encryption/tunnelling (IPSec, SSL), IP assignment, policy and logging, scalability.

5. URL/web filtering, antivirus scanning, anti-spam/phishing filter, DLP, file-type blocking, application control, SSL inspection, reporting. It enforces acceptable-use policy.

> **Done with Unit 4!**
> If you scored 4 out of 5 or more, move to **Unit 5**. If not, re-read the topics you missed in Part A.